



Instituto Politécnico Nacional
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:
Gobierno de TI | Computer Security

Tarea 15: “Técnicas para la Intrusión”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

¿Qué es un exploit?

Un exploit es código, comando o técnica que aprovecha vulnerabilidad específica para causar comportamiento no intencionado. [1][2]. Puede afectar confidencialidad, integridad o disponibilidad [3]. Existen code-based (inyecciones, buffer overflow) y non-code-based (ingeniería social) [1][4]. Se dirigen a vulnerabilidades conocidas (CVE's) o zero days [5]. La efectividad depende de complejidad vulnerabilidades, mitigaciones disponibles, y configuración específica del objetivo [2][3].

Exploit remoto vs Exploit local

Exploit remoto (RCE) se ejecuta sin acceso previo al sistema afectando servicios públicamente expuestos [1][2]. Más crítico pues requiere solo conectividad. Exploit local requiere acceso previo: usuario legítimo comprometido, shell obtenido, o acceso físico. [1][3]. Se usa para escalación de privilegios convirtiendo usuario bajo admin/root. Remoto es más crítico pero local es clave para persistencia post-intrusión. [3][5].

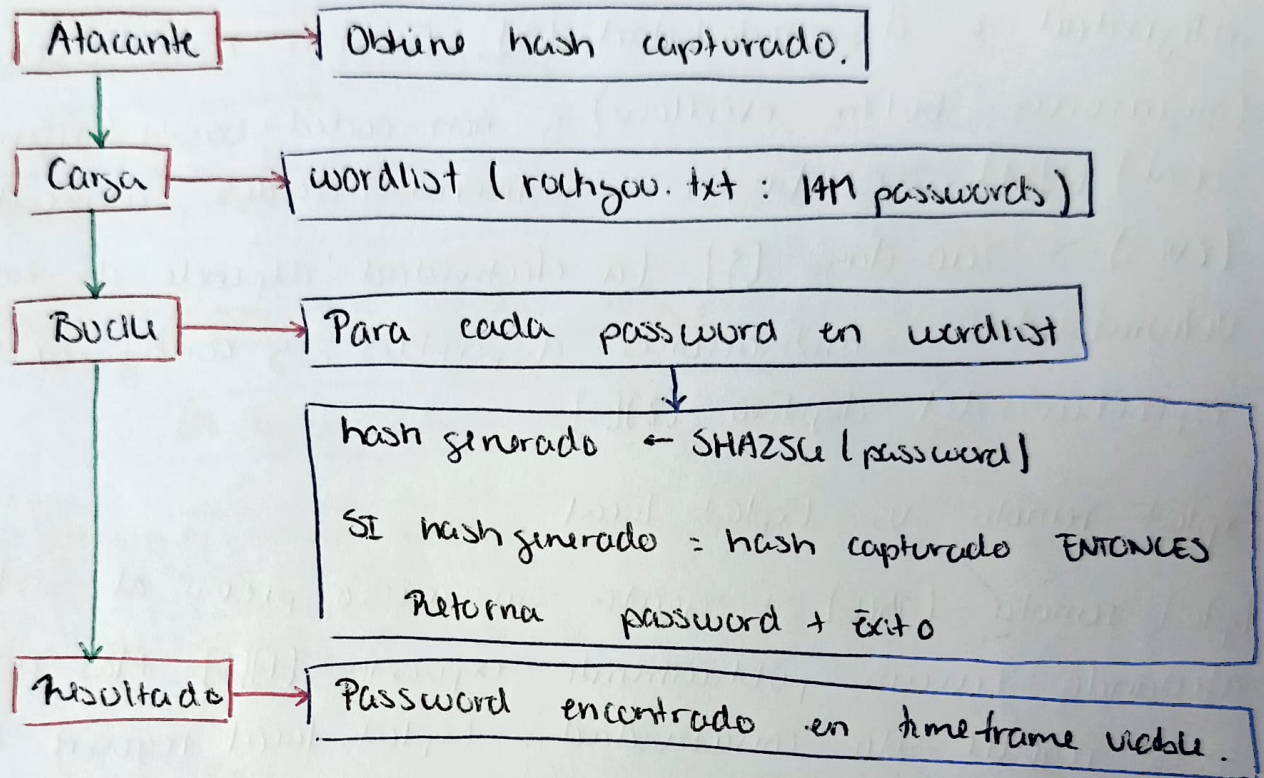
Técnica 1: SQL Injection

SQL Injection ocurre cuando una aplicación no valida entrada usuario antes pasarla a sentencia SQL. [1][2]. Atacante inserta comandos malformados mediante campos entrada (login, búsqueda) permitiendo leer datos, modificar/borrar bases de datos, eludir autenticación [3][4]. Variantes: clásica (error-based,

time-based), Blind SQLi (boolean-based), second-order [2][5].

Hurramuntas: sqlmap, Burp Suite [3]. Afecta aplicaciones sin prepared statements o input validation. [4].

Diagrama

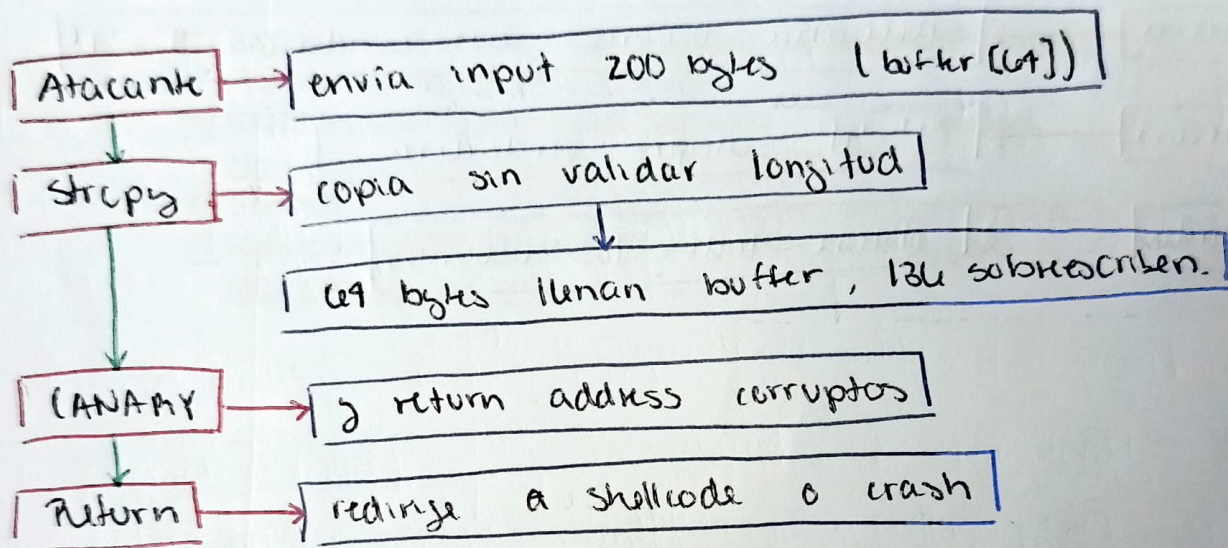
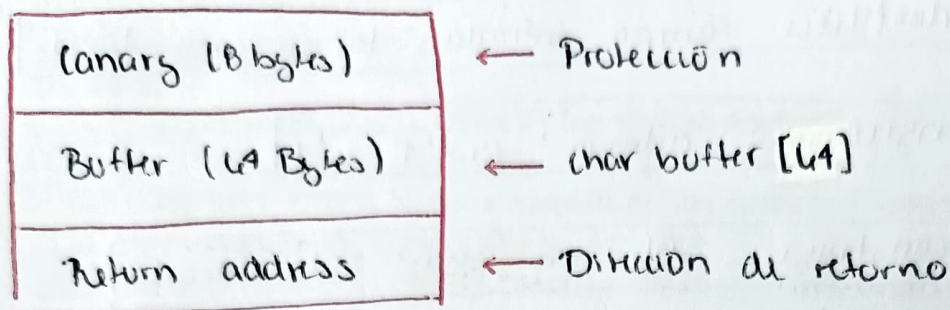


Técnica 2: Buffer Overflow

Buffer Overflow ocurre cuando programa escribe más datos en buffer que capacidad máxima asignada, sobrescribiendo memoria adyacente. Típico en C/C++ usando funciones inseguras (strcpy, sprintf, gets). [2][4]. Atacante envía input maliciosamente largo para sobrescribir return addresses, function pointers, variables críticas. Stack Overflow afecta variables locales; heap overflow afecta estructuras dinámicas [2][5]. Mitigaciones modernas: ASLR, DEP/NX, stack canaries.

Diagrama

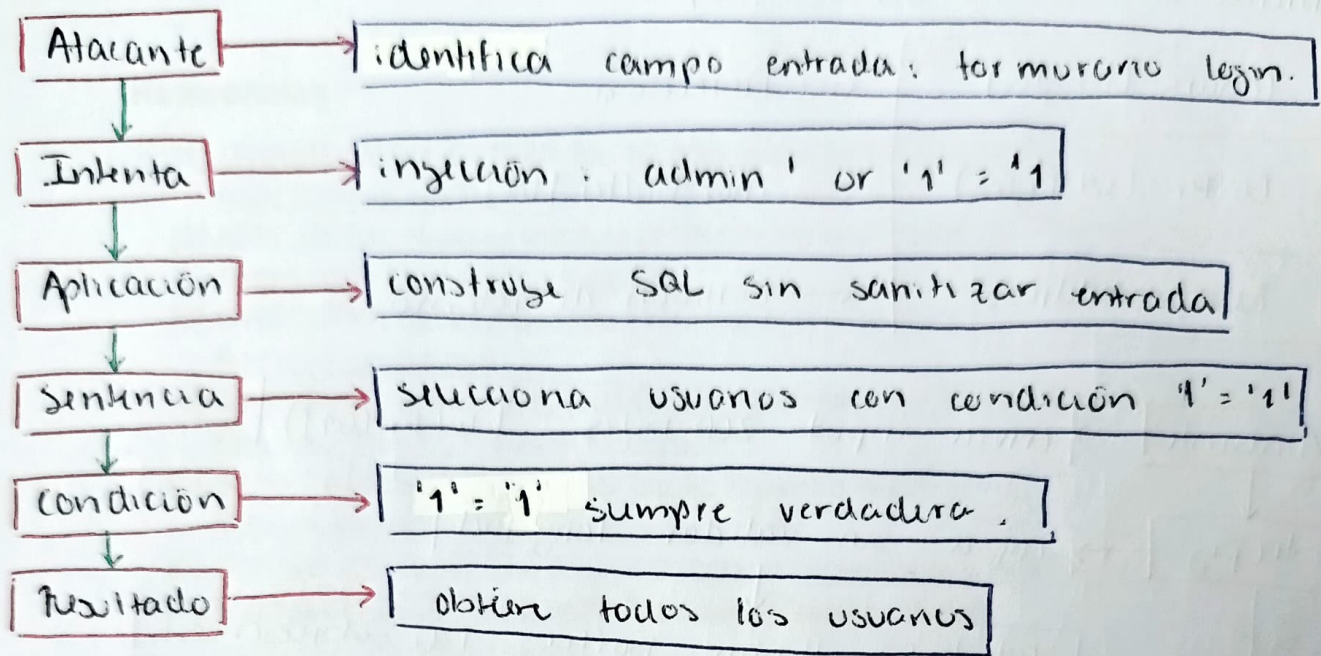
Memoria stack (antes del ataque)



Técnica 3: Fuerza Bruta

Fuerza bruta intenta combinaciones de credenciales sistemáticamente. Dictionary attack usa wordlist contra puro brute-force letra por letra [1][3]. Métodos: directo contra servicios (SSH, RDP, web) o offline contra hashes (hashcat, John The Ripper). Velocidad depende hash type, hardware attacker, salting, rate limiting [2][5]. Garantizando eventualmente pero impracticable con passwords complejos. Mitigaciones: MFA, account lockout, CAPTCHA, rate limiting.

Diagrama



Referencias

- [1]. OWASP. (2021). OWASP Top 10 Web Application Security Risks.
<https://owasp.org/Top10/>
- [2]. NIST. (2023). National Institute of Standards and Technology Cybersecurity Framework. <https://nvlpubs.nist.gov/>
- [3]. CWE/MITRE. (2024). Common Weakness Enumeration.
<https://cwe.mitre.org/>
- [4]. Stallings, W., & Brown, L. (2018). Computer Security: Principles and Practice (3rd ed.). Pearson Education.
- [5]. SANS Institute. (2024). SANS Top 25 Software Weaknesses.
<https://www.sans.org/top25-software-errors/>
- [6]. Goodwill, B. (2024). The Exploit Database. <https://www.exploit-db.com/>
- [7]. Metasploit. (2024). Metasploit Framework Documentation.
<https://docs.metasploit.com/>